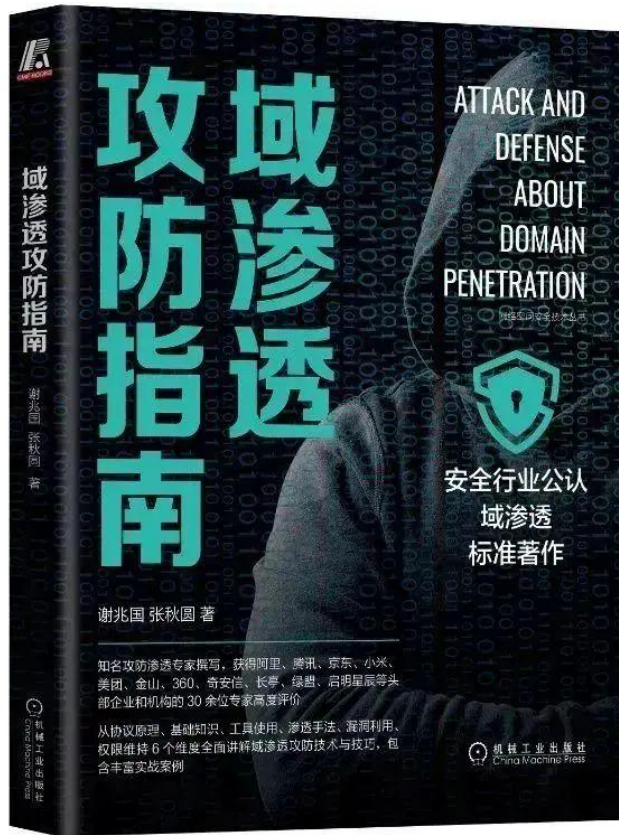


BloodHound 的使用

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

BloodHound 是一款单页的 JavaScript Web 应用程序，其建立在 Linkurious 之上，使用 Electron 编译。攻击者可以使用 BloodHound 轻松识别高度复杂的攻击路径，防守方可以使用 BloodHound 来识别和消除这些相同的攻击路径。其使用可视化图形来展示活动目录环境中隐藏的一些关系，它通过图与线的形式，将域内用户、计算机、组、会话、ACL 之间的关系呈现出来。

项目地址：<https://github.com/BloodHoundAD>

BloodHound 的安装和使用

如下是 BloodHound 的安装过程以及安装后的使用过程。以下我演示在 Mac OS 系统上安装和使用 BloodHound。

1. 安装 Neo4j 数据库

BloodHound 使用 Neo4j 数据库存储数据，Neo4j 是一款 NoSQL 图形数据库，它将结构化数据存储在网络内而不是表中。BloodHound 正是利用 Neo4j 这种特性，通过合理的分析，直观地以节点空间的形式展示相关数据。因此在安装 BloodHound 之前需要先安装 Neo4j 数据库。而 Neo4j 数据库的运行需要 Java 环境的支持，因此还需要先安装 Java 环境。

如图所示，已经安装好了 Java 环境，java 版本为 11.0.8。

```
→ ~ java -version
java version "11.0.8" 2020-07-14 LTS
Java(TM) SE Runtime Environment 18.9 (build 11.0.8+10-LTS)
Java HotSpot(TM) 64-Bit Server VM 18.9 (build 11.0.8+10-LTS, mixed mode)
```

安装完 Java 环境后，去 Neo4j 官网下载社区免费版：

<https://neo4j.com/download-center/#community>。

如图所示，这里我下载的是 Neo4j-community-4.1.11 版本。

Neo4j Community Edition 4.1.11

16 November 2021 [Release Notes](#) | [Read More](#)

OS	Download
Linux/Mac	Neo4j 4.1.11 (tar) SHA-256
Windows	Neo4j 4.1.11 (zip) SHA-256

下载后，将安装包解压，进入解压后的 bin 目录，然后打开命令行窗口，执行如下命令，启动 Neo4j 服务。

```
./neo4j console
```

如图所示，可以看到已经启动了 Neo4j 了。

```
+ neo4j-community-4.1.11 cd bin
+ bin ls
LICENSE.txt  LICENSES.txt  NOTICE.txt  cypher-shell  neo4j          neo4j-admin  tools
+ bin ./neo4j console
Directories in use:
home:      /Users/xie/Desktop/neo4j-community-4.1.11
config:    /Users/xie/Desktop/neo4j-community-4.1.11/conf
logs:      /Users/xie/Desktop/neo4j-community-4.1.11/logs
plugins:    /Users/xie/Desktop/neo4j-community-4.1.11/plugins
import:     /Users/xie/Desktop/neo4j-community-4.1.11/import
data:      /Users/xie/Desktop/neo4j-community-4.1.11/data
certificates: /Users/xie/Desktop/neo4j-community-4.1.11/certificates
run:       /Users/xie/Desktop/neo4j-community-4.1.11/run
Starting Neo4j.
2022-01-28 10:34:15.651+0000 INFO  Starting...
2022-01-28 10:34:17.681+0000 INFO  ===== Neo4j 4.1.11 =====
2022-01-28 10:34:19.191+0000 INFO  Performing postInitialization step for component 'security-users' with version 2 and status CURRENT
2022-01-28 10:34:19.191+0000 INFO  Updating the initial password in component 'security-users'
2022-01-28 10:34:19.814+0000 INFO  Bolt enabled on localhost:7687.
2022-01-28 10:34:21.036+0000 INFO  Remote interface available at http://localhost:7474/
2022-01-28 10:34:21.037+0000 INFO  Started.
```

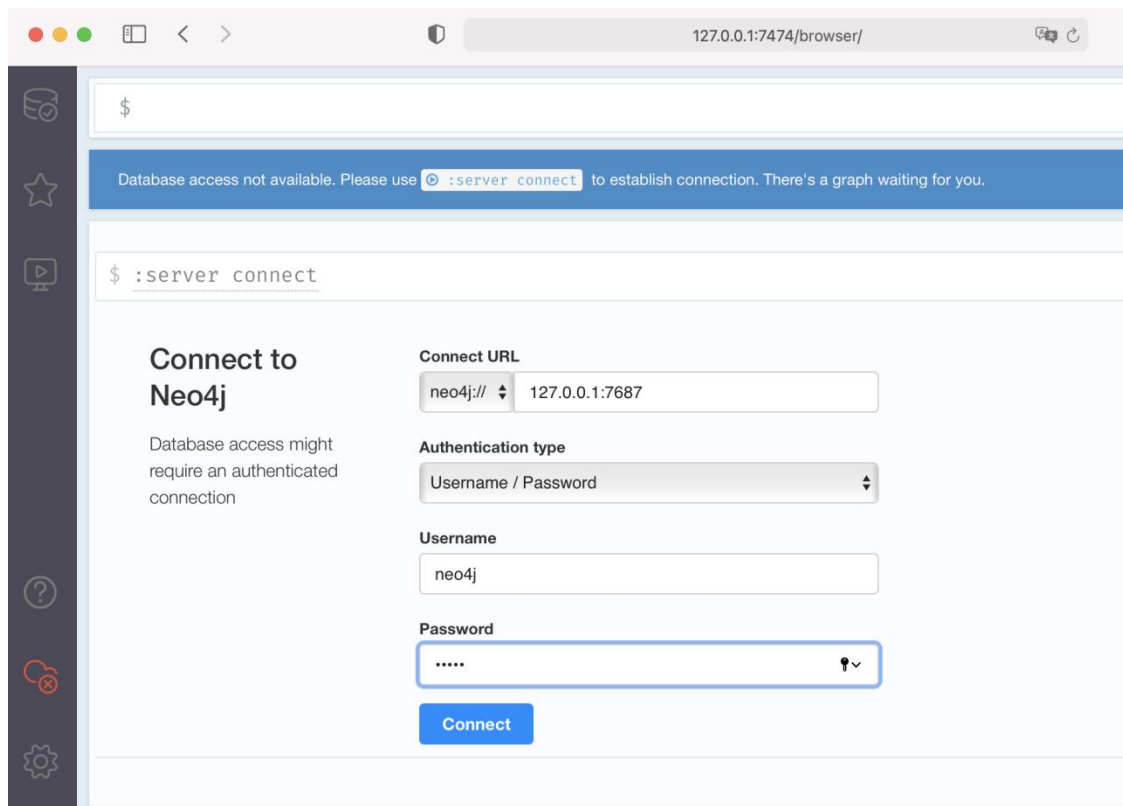
服务启动后，浏览器打开 URL：<http://127.0.0.1:7474/browser/>，然后在打开的页面中输入如下信息连接点击 Connect 即可：

Connect Url: neo4j://127.0.0.1:7687

Username: neo4j

Password: neo4j

如图所示，浏览器打开 <http://127.0.0.1:7474/browser/>，输入相应信息进行连接。



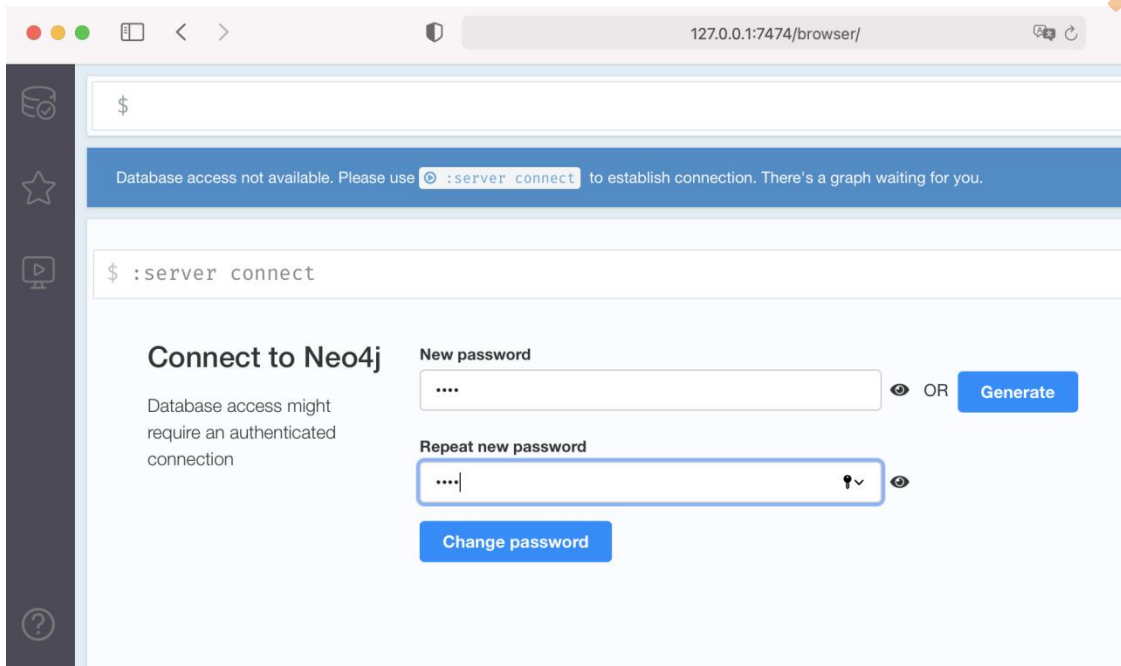
The screenshot shows a web browser window with the address bar displaying `127.0.0.1:7474/browser/`. The page content includes a sidebar on the left with icons for home, star, and play. The main area has a header with a message: "Database access not available. Please use `:server connect` to establish connection. There's a graph waiting for you." Below this is a search bar containing `$ :server connect`. The main section is titled "Connect to Neo4j" and contains a form with the following fields:

- Connect URL:** A text input field containing `neo4j://` and `127.0.0.1:7687`.
- Authentication type:** A dropdown menu with the selected option "Username / Password".
- Username:** A text input field containing `neo4j`.
- Password:** A password input field with masked characters (dots) and a visibility toggle icon.
- Connect:** A blue button to submit the form.

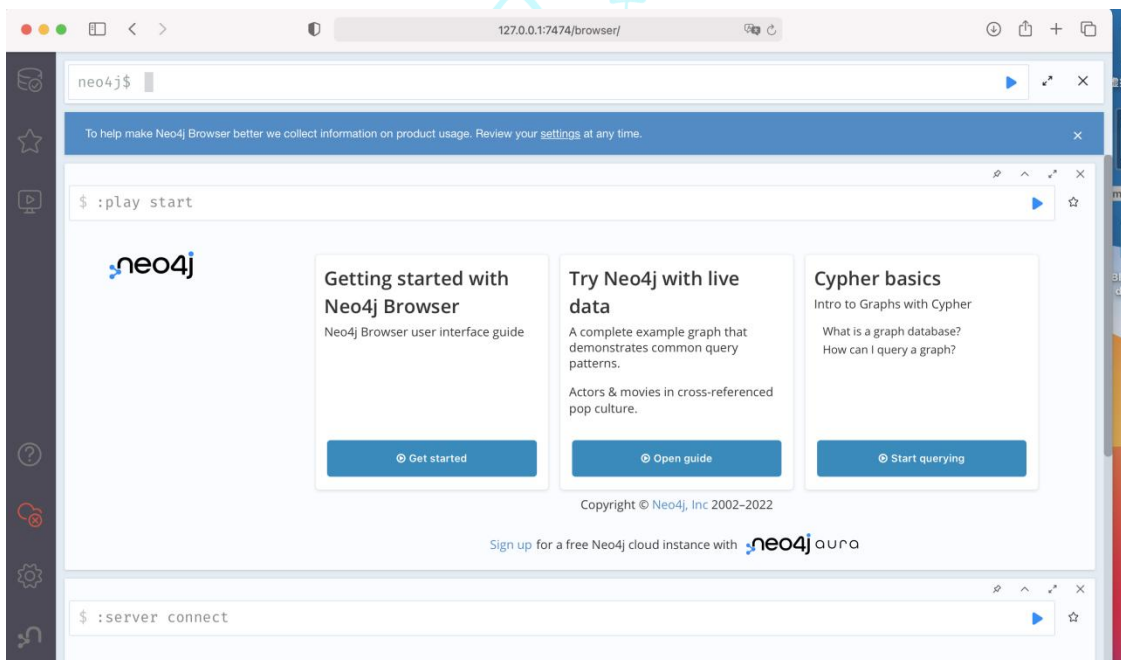
Below the form, there is a note: "Database access might require an authenticated connection".

点击 Connect，连接成功后，第一次会让我们修改密码，这里将密码修改为其他字符，然后点击 Change password 即可。

如图所示，修改密码。



重置完密码之后，就可以正常使用 Neo4j 了。如图所示：

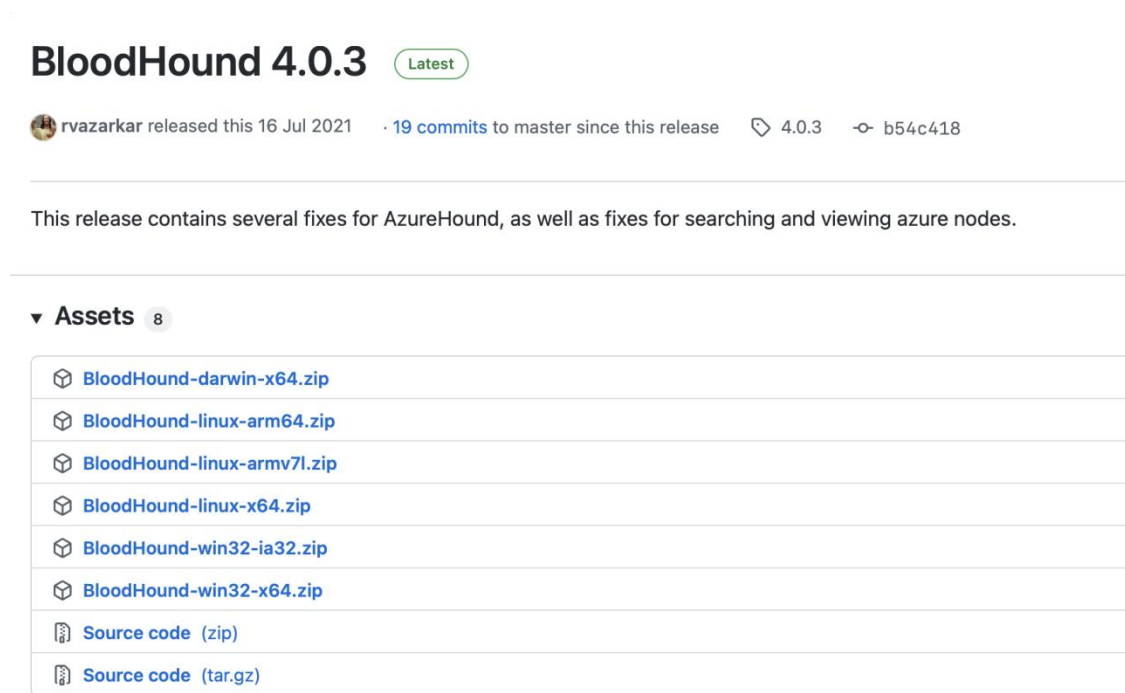


2. 运行 BloodHound

安装完 Neo4j 后，就可以运行 BloodHound 了。去 github 下载 BloodHound：

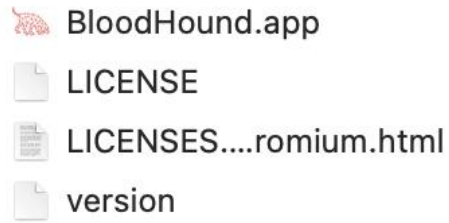
<https://github.com/BloodHoundAD/BloodHound/releases/tag/4.0.3>。

如图所示，找到对应系统架构的下载即可：



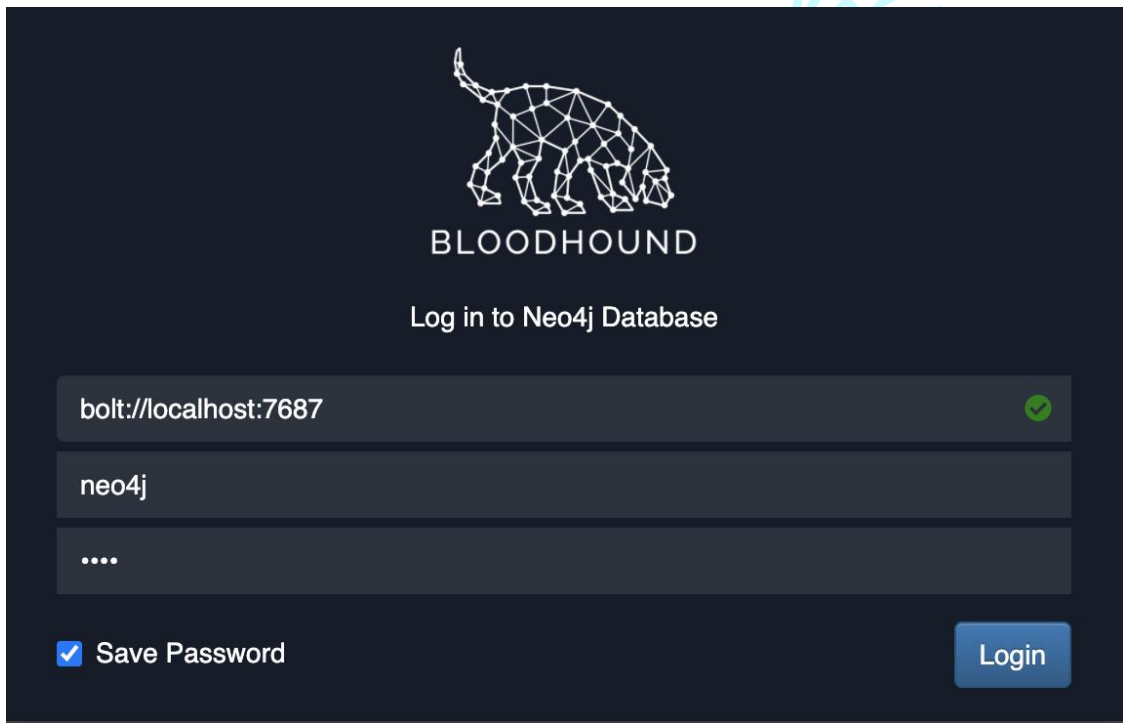
我这里下载的是 Mac 版本的 BloodHound-darwin-x64。下载后解压，进入解压目录，找到 BloodHound.app，双击打开即可。

如图所示，是解压后的 BloodHound-darwin-x64。

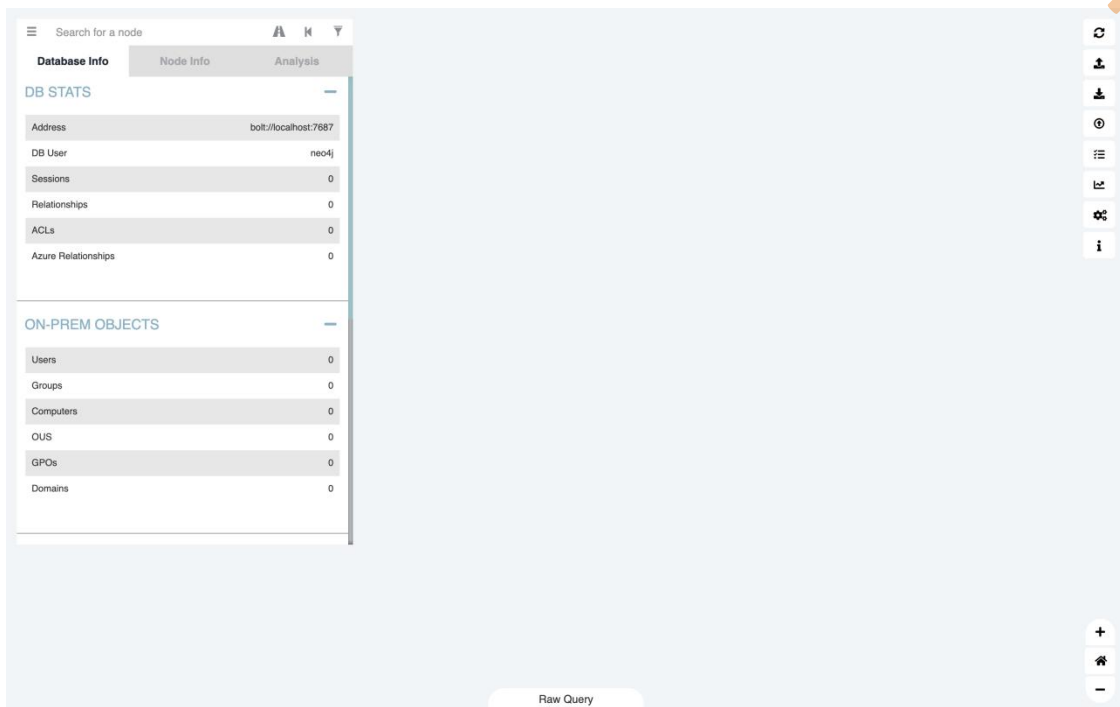


然后输入安装 Neo4j 时的账号密码点击 Login 即可。

如图所示，输入账号密码登录。



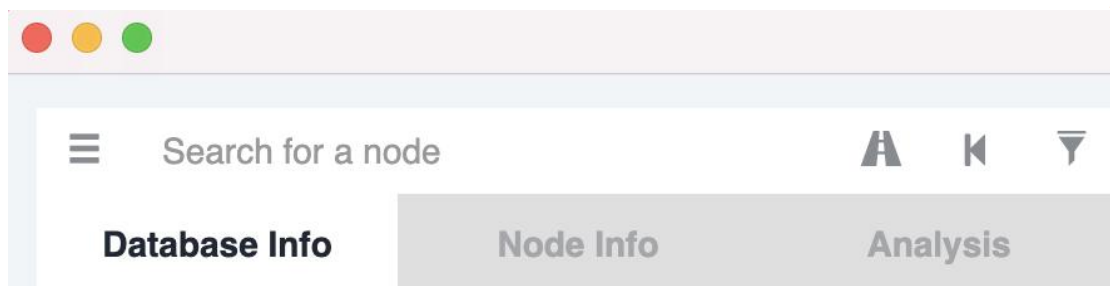
登录成功后打开 BloodHound 如图所示：



界面左上角是菜单按钮和搜索栏。三个选项卡分别是：

- 数据库信息 Database Info：数据库信息选项卡中显示了所分析域的用户数量、计算机数量、组数量、OU 数量、GPO 数量和域数量、会话数量、ACL 数量、关系等信息；用户可以在此处执行基本的数据库管理操作，包括注销和切换数据库，以及清除当前加载的数据库。
- 节点信息 Node Info：节点信息选项卡中显示了用户在图表中单击的节点的信息。
- 分析 Analytics：查询选项卡中显示了 BloodHound 预置的查询请求和用户自己构建的查询请求。

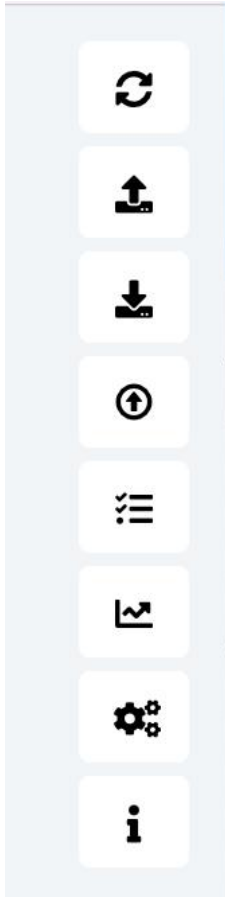
如图是界面左上角截图。



界面右上角是设置区。

1. 第一个是刷新 Refresh 功能，BloodHound 将重新计算并绘制当前显示的图形；
2. 第二个是导出图形 Export Graph 功能，可以将当前绘制的图形导出为 JSON 或 PNG 文件；
3. 第三个是导入图形 Import Graph 功能，可以导入 JSON 文件；
4. 第四个是上传数据 Upload Data 功能，BloodHound 将对上传的文件进行自动检测，然后获取 CSV 格式的数据；
5. 第五个是查看上传状态 View Upload Status 功能；
6. 第六个是更改布局类型 Change Layout Type 功能，用于在分层和强制定向图布局之间切换；
7. 第七个是设置 Settings 功能，可以更改节点的折叠行为，以及在不同的细节模式之间切换；
8. 第八个是关于 About 功能，显示当前 BloodHound 版本等信息。

如图是界面右上角截图：



界面右下角是对当前的图形进行放大和缩小等操作，如图所示是界面右下角截

图：



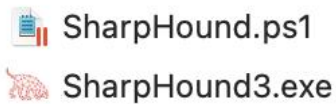
活动目录信息收集

进行完前期的安装操作后，就要开始收集活动目录的相关信息了！使用 BloodHound 进行信息收集有两种方案：

1. 一是 PowerShell 采集器脚本 SharpHound.ps1。
2. 二是可执行文件 SharpHound.exe。

这里我们建议使用 exe 工具。

如图所示， 是最新的 SharpHound3.exe 工具和 SharpHound.ps1 脚本。



然后我们使用 SharpHound3.exe 执行如下命令进行信息收集，使用普通域用户权限执行如下命令即可进行信息收集。

```
SharpHound3.exe -c all
```

如图所示，可以看到已经收集完域内的相关信息了！执行完成后，会在当前目录生成下如下格式的文件 时间戳_BLOODHOUND.zip

```
C:\Users\hack.XIE\Desktop>SharpHound3.exe -c all
-----
Initializing SharpHound at 19:20 on 2022/1/28
-----
Resolved Collection Methods: Group, Sessions, LoggedOn, Trusts, ACL, ObjectProps, LocalGroups, SPNTargets, Container
[+] Creating Schema map for domain XIE.COM using path CN=Schema,CN=Configuration,DC=xie,DC=com
[+] Cache File not Found: 0 Objects in cache
[+] Pre-populating Domain Controller SIDS
Status: 0 objects finished (+0) -- Using 21 MB RAM
Status: 106 objects finished (+106 106)/s -- Using 28 MB RAM
Enumeration finished in 00:00:01.7323618
Compressing data to .\20220128192022_BloodHound.zip
You can upload this file directly to the UI
SharpHound Enumeration Completed at 19:20 on 2022/1/28! Happy Graphing!
```

如下使用 SharpHound.ps1 脚本收集。

Import-Module .\SharpHound.ps1;Invoke-BloodHound

```
PS C:\Users\Administrator\Desktop> Import-Module .\SharpHound.ps1;Invoke-BloodHound
Initializing BloodHound at 21:02 on 2022/5/23
Resolved Collection Methods to Group, LocalAdmin, Session, Trusts, RDP, DCOM
Starting Enumeration for xie.com
Status: 55 objects enumerated (+55 27.5/s --- Using 97 MB RAM )
Finished enumeration for xie.com in 00:00:02.4532229
1 hosts failed ping. 0 hosts timedout.

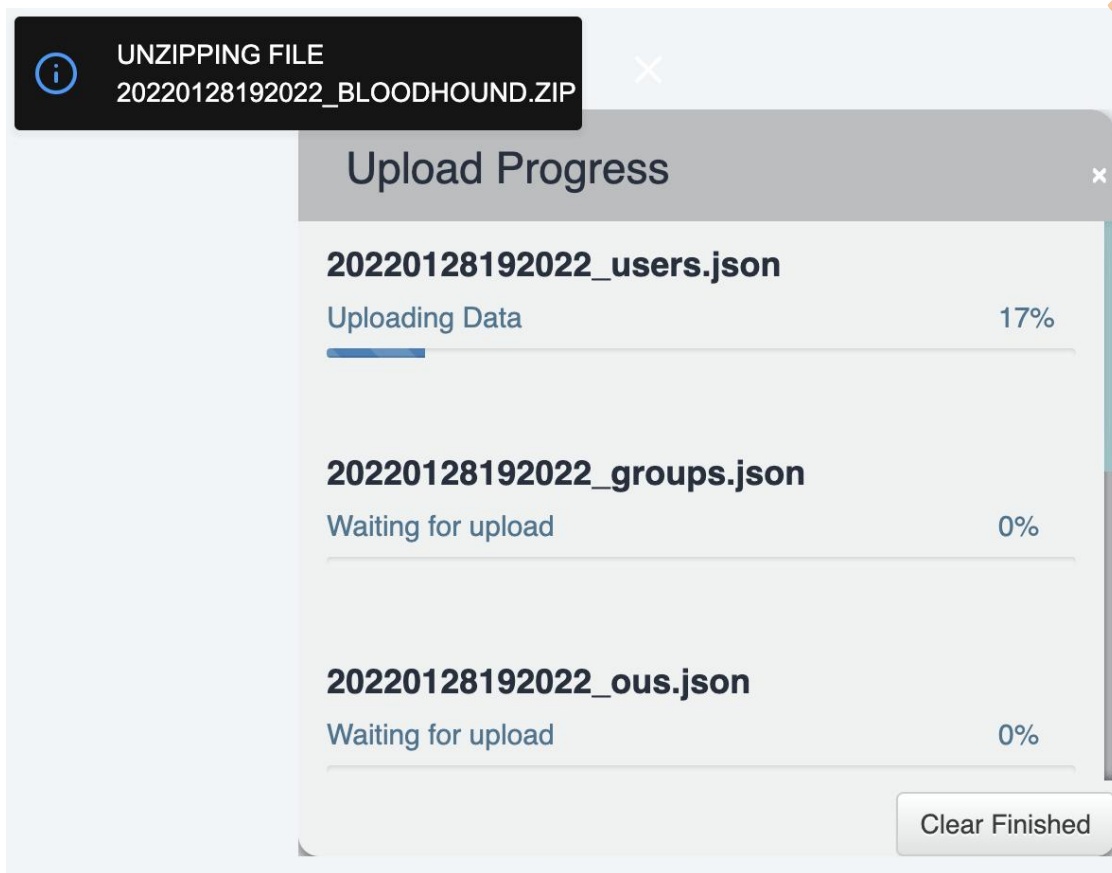
Compressing data to C:\Users\Administrator\Desktop\20220523210216_BloodHound.zip.
You can upload this file directly to the UI.
Finished compressing files!
```

导入数据

BloodHound 支持通过界面上传单个文件和 ZIP 文件，最简单的方法是将压缩文件拖放到界面上任意空白位置。

如图所示，将上一步信息收集到的.zip 压缩文件拖放到空白处后，可以看到导入的进度。等待导入到 100%即可。





数据库信息

文件导入后，即可通过 Database Info 查看该域的相关信息。

如图所示，该域有 29 个用户、4 台主机、69 个组，0 个 sessions，998 条 ACLs、1121 个关系，6 个 OU 组织单位，2 个 GPO 组策略。

 Search for a node**Database Info****Node Info****Analysis**

DB STATS

Address	bolt://localhost:7687
DB User	neo4j
Sessions	0
Relationships	1121
ACLs	998
Azure Relationships	0

ON-PREM OBJECTS

Users	29
Groups	69
Computers	4
OUS	6
GPOs	2
Domains	1

节点信息

点击中间的 Node Info 即可看节点的信息。这里默认显示的是当前域的信息。

如图所示，可以从节点信息中得到域功能级别、域的 SID、域内的用户、组、主机、OU 组织单位、GPO 等信息。





Search for a node



Database Info

Node Info

Analysis

XIE.COM

OVERVIEW

Users	29
Groups	67
Computers	4
OUs	6
GPOs	2
Map OU Structure	

NODE PROPERTIES

Object ID	S-1-5-21-1313979556-3624129433-4055459191
Domain Functional Level	2012 R2

EXTRA PROPERTIES

distinguishedname	DC=xie,DC=com
domain	XIE.COM
name	XIE.COM

FOREIGN MEMBERS

如果我们点击图形中的某个节点，Node Info 节点信息这里就会显示对应的目标的一些信息。如图所示，是 administrator 的一些信息：

ADMINISTRATOR@XIE.COM

OVERVIEW

Sessions	0
Sibling Objects in the Same OU	28
Reachable High Value Targets	9
Effective Inbound GPOs	1
See user within Domain/OU Tree	

NODE PROPERTIES

Display Name	Administrator
Object ID	S-1-5-21-1313979556-3624129433-4055459191-500
Password Last Changed	Sun, 10 Oct 2021 08:36:15 GMT
Last Logon	Mon, 13 Dec 2021 08:53:33 GMT
Last Logon (Replicated)	Mon, 13 Dec 2021 08:48:24 GMT
Enabled	True
Email	Administrator@xie.com

The graph on the right shows the following relationships:

- A red line labeled "MemberOf" connects the selected node (ADMINISTRATOR@XIE.COM) to a node labeled DOMAIN ADMINS@XIE.COM.
- A blue line labeled "MemberOf" connects the DOMAIN ADMINS@XIE.COM node to a node labeled ADMIN@XIE.COM.

分析模块

点击左上角右边的 Analysis 分析模块，可以看到预定义的一些常用查询条件，如图是 BloodHound 内置的一些查询条件：



Search for a node



Database Info

Node Info

Analysis

Pre-Built Analytics Queries

Find all Domain Admins
Find Shortest Paths to Domain Admins
Find Principals with DCSync Rights
Users with Foreign Domain Group Membership
Groups with Foreign Domain Group Membership
Map Domain Trusts
Shortest Paths to Unconstrained Delegation Systems
Shortest Paths from Kerberoastable Users
Shortest Paths to Domain Admins from Kerberoastable Users
Shortest Path from Owned Principals
Shortest Paths to Domain Admins from Owned Principals
Shortest Paths to High Value Targets
Find Computers where Domain Users are Local Admin
Find Computers where Domain Users can read LAPS passwords
Shortest Paths from Domain Users to High Value Targets
Find All Paths from Domain Users to High Value Targets
Find Workstations where Domain Users can RDP
Find Servers where Domain Users can RDP
Find Dangerous Rights for Domain Users Groups
Find Kerberoastable Members of High Value Groups
List all Kerberoastable Accounts
Find Kerberoastable Users with most privileges
Find Domain Admin Logons to non-Domain Controllers
Find Computers with Unsupported Operating Systems
Find AS-REP Roastable Users (DontReqPreAuth)

以下是这些查询条件的解释：

1. Find all Domain Admins：查找所有域管理员组
2. Find Shortest Paths to Domain Admins：查找到达域管理员组的最短路径
3. Find Principals with DCSync Rights：查找具有 DCSync 权限的主体
4. Users with Foreign Domain Group Membership：具有外部域组成员身份的用户
5. Groups with Foreign Domain Group Membership：具有外部域组成员身份的组
6. Map Domain Trusts：映射域信任关系
7. Shortest Paths to Unconstrained Delegation Systems：到达无约束性委派系统的最短路径
8. Shortest Paths from Kerberoastable Users：到达能进行 Kerberoasting 攻击的用户(也就是具有 SPN 的用户)的最短路径
9. Shortest Paths to Domain Admins from kerberoastable Users：从能进行 Kerberoasting 攻击的用户到域管理员组的最短路径
10. Shortest Path from Owned Principals：所属主体的最短路径
11. Shortest Paths to Domain Admins from Owned Principals：从所属主体到域管理员的最短路径

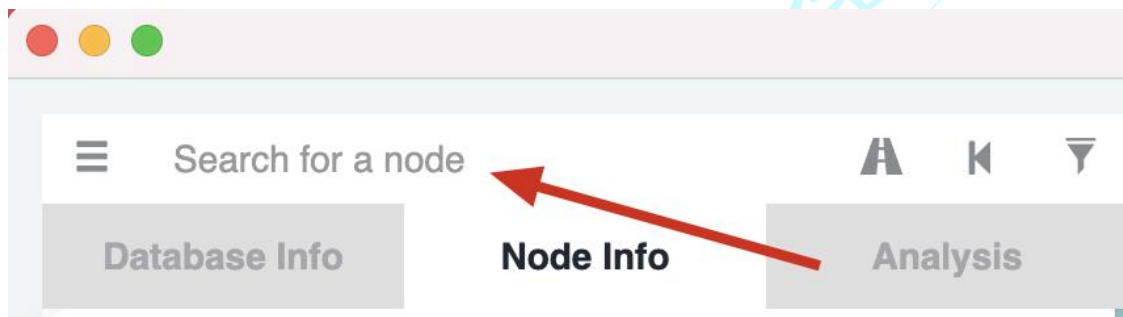
12. Shortest Paths to High Value Targets: 高价值目标的最短路径
13. Find Computers where Domain Users are Local Admin: 查找域用户是本地管理员的计算机
14. Find Computers where Domain Users can read LAPS passwords: 查找域用户可以读取 LAPS 密码的计算机
15. Shortest Paths from Domain Users to High Value Targets: 从域用户到高值目标的最短路径
16. Find All Paths from Domain Users to High Value Targets: 查找从域用户到高值目标的所有路径
17. Find Workstations where Domain Users can RDP: 找到域用户可以进行 RDP 操作的工作站
18. Find Servers where Domain Users can RDP: 查找普通域用户能 RDP 的服务器
19. Find Dangerous Rights for Domain Users Groups: 查找域用户组的危险权限
20. Find Kerberoastable Members of High Value Groups: 从高价值的组中发现能进行 Kerberoasting 攻击的帐户
21. List all Kerberoastable Accounts: 列出所有的能进行 Kerberoasting 攻击的帐户
22. Find Kerberoastable Users with most privileges: 找到具有大多数特权的能进行 Kerberoastable 攻击的用户
23. Find Domain Admin Logons to non-Domain Controllers: 查找域管理员登录过的不是域控的机器

24. Find Computers with Unsupported Operating Systems:
查找具有不受支持的操作系统的计算机

25. Find AS-REP Roastable Users (DontReqPreAuth): 查找能
进行 AS-REP Roasting 攻击的用户，也就是不需要域认证的用户

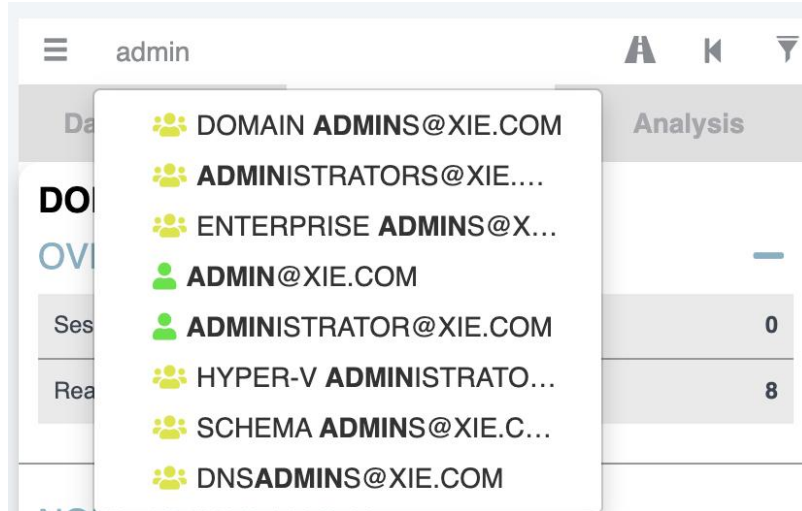
查询模块

如果我们想查询信息，可以直接点击左上角的 Search for a node，如图所示：



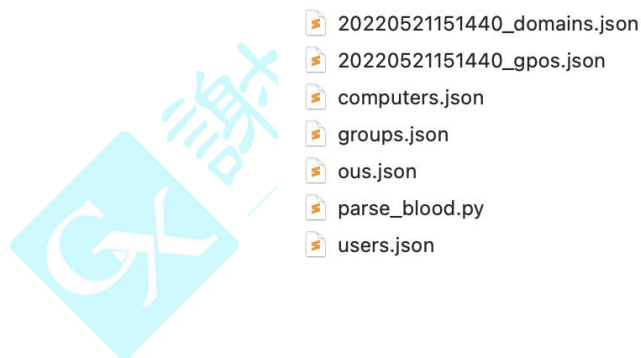
比如要查询 admin 相关的东西，输入 admin，下面就会出来带有 admin 字符的相关信息。

如图所示，出来了很多带有 admin 的节点。然后再点击要查询的节点即可！



解析导出的 json 文件

使用 SharpHound3.exe 导出的是 json 格式的数据，现在需要将其解析成可读格式的。将 users、computers、groups、ous 这四个文件去除时间戳，如下。然后将 parse_blood.py 解析文件放入同一目录下。



运行即可解析域用户、域机器、域组和域 OU。

```
→ 20220521151440_BloodHound python3 parse_blood.py
```

```
-----解析域用户-----
```

```
ADMINISTRATOR@XIE.COM  
TEST@XIE.COM  
HACK@XIE.COM  
ADDDOMAIN@XIE.COM  
GUEST@XIE.COM  
KRBTGT@XIE.COM
```

```
-----解析域机器-----
```

```
DC01.XIE.COM  
SERVER2008.XIE.COM  
CA-SERVER.XIE.COM
```

```
-----解析域组-----
```

```
USERS@XIE.COM  
REPLICATORS@XIE.COM  
BACKUP OPERATORS@XIE.COM  
REMOTE DESKTOP USERS@XIE.COM  
NETWORK CONFIGURATION OPERATORS@XIE.COM  
PERFORMANCE LOG USERS@XIE.COM  
DISTRIBUTED COM USERS@XIE.COM  
PERFORMANCE MONITOR USERS@XIE.COM  
ADMINISTRATORS@XIE.COM  
GUESTS@XIE.COM  
IIS_IUSRS@XIE.COM  
PRINT OPERATORS@XIE.COM  
CRYPTOGRAPHIC OPERATORS@XIE.COM  
EVENT LOG READERS@XIE.COM  
RDS REMOTE ACCESS SERVERS@XIE.COM  
RDS ENDPOINT SERVERS@XIE.COM  
CERTIFICATE SERVICE DCOM ACCESS@XIE.COM  
RDS MANAGEMENT SERVERS@XIE.COM  
ACCESS CONTROL ASSISTANCE OPERATORS@XIE.COM  
HYPER-V ADMINISTRATORS@XIE.COM  
REMOTE MANAGEMENT USERS@XIE.COM  
CERT PUBLISHERS@XIE.COM
```

运行完成后，会在当前目录下生成如下文件。



- 20220521151440_domains.json
- 20220521151440_gpos.json
- computers.json
- domain_computer.txt
- domain_group.txt
- domain_ou.txt
- domain_user.txt
- groups.json
- ous.json
- parse_blood.py
- users.json

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习AD域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习


域渗透攻防指南
星主：谢公子

60+	30+	306
成员数量	内容数量	运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



知识星球 谢公子学安全